

CYBER THREAT INTELLIGENCE REPORT

European Commission

Europa Platform

Cloud Infrastructure Breach

AWS Account Compromise & 350 GB+ Data Exfiltration

5W1H Deep-Dive Analysis

Incident Date	24 March 2026
Report Date	29 March 2026 (v4.0)
Claimed Actor	ShinyHunters
Severity	HIGH
Status	Investigation Ongoing
Classification	TLP:CLEAR

- [1. Executive Summary](#)
 - [1.1 Intelligence Confidence Framework](#)
- [2. WHAT — Nature of the Incident](#)
 - [2.1 Incident Classification](#)
 - [2.2 Scope of Compromise: Confirmed vs Claimed](#)
 - [2.3 Blast Radius Assessment](#)
- [3. WHO — Threat Actor Attribution](#)
 - [3.1 Victim Profile](#)
 - [3.2 Claimed Actor: ShinyHunters](#)
 - [3.3 Threat Actor Profile & Operational Evolution](#)
 - [3.4 Mandiant/GTIG Threat Cluster Tracking](#)
 - [3.5 Expert Assessment on Motivation & Attribution](#)
- [4. WHEN — Consolidated Incident Timeline](#)
- [5. WHERE — Attack Surface & Infrastructure](#)
 - [5.1 Target Environment](#)
 - [5.2 Europa Platform Technology Stack & Attack Surface](#)
 - [5.3 Architectural Segmentation & Shared Responsibility Assessment](#)
- [6. WHY — Motive & Strategic Context](#)
 - [6.1 Stated Motive: Leak, Not Extort](#)
 - [6.2 Possible Motive Categories](#)
 - [6.3 Geopolitical Context: The 16 March Sanctions Factor](#)
- [7. HOW — Attack Vector & Technical Analysis](#)
 - [7.1 Known and Assessed Attack Vectors](#)
 - [7.2 ShinyHunters Known TTPs \(MITRE ATT&CK Mapping\)](#)
 - [7.3 Expert Technical Commentary](#)
 - [7.4 Incident Response Actions \(Confirmed & Assessed\)](#)
 - [7.5 Open Investigative Questions](#)
- [8. Strategic Implications & Outlook](#)
 - [8.1 Pattern Recognition: Escalating Institutional Targeting](#)
 - [8.2 Cloud Security Paradigm Shift](#)
 - [8.3 The “No Ransom” Pivot: A New Playbook](#)
 - [8.4 Regulatory Ironies & Digital Sovereignty](#)
 - [8.5 Forward-Looking Threat Assessment](#)
- [9. Defensive Recommendations](#)
 - [9.1 Identity & Access Management \(Priority 1\)](#)
 - [9.2 Detection & Monitoring \(Priority 2\)](#)
 - [9.3 Architecture & Blast Radius Reduction \(Priority 3\)](#)
 - [9.4 Human Layer Resilience \(Priority 4\)](#)
 - [9.5 Immediate Downstream Actions](#)
- [10. Sources & References](#)

- [10.1 Official Statements & Primary Reporting](#)
- [10.2 Threat Actor Attribution & Dark Web Reporting](#)
- [10.3 Expert Analysis & Security Commentary](#)
- [10.4 Prior Incidents & Contextual Intelligence](#)
- [10.5 Technical References & Platform Documentation](#)

DISCLAIMER

This Cyber Threat Intelligence (CTI) report is provided for informational and educational purposes only. It is classified TLP:CLEAR under the Traffic Light Protocol, meaning it may be distributed without restriction and shared publicly.

This report has been compiled from publicly available open-source intelligence (OSINT), including official press releases, news reporting, security research publications, and dark web monitoring. Every effort has been made to ensure accuracy; however, the authors make no warranties, express or implied, regarding the completeness, reliability, or fitness for any particular purpose of the information contained herein.

Certain information in this report is based on claims made by threat actors that have not been independently verified or confirmed by the victim organisation. Such claims are clearly identified throughout the report and should be treated with appropriate caution. Attribution assessments reflect analytical judgment at the time of writing and may be revised as new evidence emerges.

This report does not constitute legal advice, incident response guidance, or a substitute for professional cybersecurity consultation. Organisations should conduct their own due diligence and engage qualified professionals before making security decisions based on the information presented.

The inclusion of vendor names, product names, or organisational identifiers in this report is for factual reporting purposes only and does not imply endorsement, affiliation, or liability. Amazon Web Services (AWS) has publicly confirmed that its infrastructure was not breached in this incident.

The authors and distributors of this report accept no liability for any loss, damage, or consequence arising directly or indirectly from the use of or reliance on any information contained in this document.

1. Executive Summary

On 24 March 2026, the European Commission detected a significant cyberattack targeting its Amazon Web Services (AWS) cloud infrastructure, which hosts its public-facing Europa.eu web platform. The cybercrime group ShinyHunters subsequently claimed responsibility, posting the Commission to their Tor data leak site on 26 March and asserting the exfiltration of over 350 GB of data encompassing mail server dumps, internal databases, confidential documents, and contracts. The attacker provided BleepingComputer with screenshots evidencing access to employee information and a Commission email server.

The Commission confirmed that internal systems and core administrative networks were not compromised, and Europa.eu websites remained operational throughout the incident. AWS stated its infrastructure was not breached, placing the compromise squarely within the customer account management layer — a textbook illustration of the AWS Shared Responsibility Model. The threat actor explicitly stated they will not seek ransom and intend to leak the data publicly, signalling a hacktivist, geopolitically motivated, or purely disruptive intent.

This is the second confirmed cyberattack against the European Commission in 2026, following a January breach of its Mobile Device Management (MDM) infrastructure linked to the exploitation of an Ivanti EPMM zero-day. Critically, the incident occurred just eight days after the EU Council adopted new cyber sanctions on 16 March targeting Chinese entities (Integrity Technology Group / Flax Typhoon, Anxun Information Technology / iSoon) and Iranian entity Emennet Pasargad — raising questions about potential retaliatory or politically motivated targeting.

KEY FINDINGS

ShinyHunters posted the European Commission's data to their Tor data leak site on 26 March, claiming 350+ GB of stolen data, including mail servers, databases, confidential documents, and contracts.

The group stated that it will not attempt extortion but intends to leak data publicly — a departure from its standard "pay or leak" model, signalling a motive for political or reputational damage.

The breach targeted the cloud account management layer (IAM/credentials), not the underlying AWS infrastructure — consistent with the AWS Shared Responsibility Model.

The attack occurred 8 days after the EU Council sanctioned Chinese and Iranian cyber-offensive entities on 16 March 2026, a potentially significant geopolitical accelerant.

1.1 Intelligence Confidence Framework

This report applies a structured confidence framework across all claims. Not all information carries equal evidentiary weight. The following matrix should be used when interpreting any assertion in this report:

Confidence	Criteria	Key Claims at This Level
HIGH	Confirmed by the European Commission in official press releases or by independent technical verification.	Discovery date: 24 March 2026. Affected zone: cloud infrastructure hosting Europa.eu. Data was likely taken. Internal systems were not affected. Investigation is ongoing; Union entities are being notified.
MEDIUM	Reported by credible media (BleepingComputer, TechCrunch, Bloomberg) citing named sources or direct threat actor contact, but not confirmed by the Commission.	Compromise involved at least one AWS account. The threat actor may have accessed ~350 GB of data, including databases. The threat actor claims access to a Commission employee email server and employee data.
MEDIUM-HIGH	Self-claimed by a threat actor on an established platform, consistent with documented MO, corroborated by multiple independent researchers, but lacking victim or law-enforcement confirmation.	ShinyHunters is the responsible actor (Alvieri, Security Affairs, Hackread, and RedPacket Security confirmed the Tor leak site posting).
LOW / UNVERIFIED	Single-source claims, threat actor assertions not independently validated, or speculative inference.	Full list of stolen data types (mail dumps, contracts, confidential documents). Specific initial access vector used—any connection between this incident and the 16 March EU sanctions or the January MDM breach.

2. WHAT — Nature of the Incident

2.1 Incident Classification

The attack is classified as a cloud account compromise leading to large-scale data exfiltration. At least one of the European Commission's AWS accounts was breached, granting the threat actor access to the cloud environment that hosts the Commission's public web presence on the Europa.eu platform. The Europa domain serves as the principal public gateway for EU institutional websites, legislation, press releases, consultations, and policy materials across all 27 member states.

Field	Detail
Incident Type	Cloud account compromise + data exfiltration
Target System	AWS account(s) hosting the Europa.eu web platform
Data Volume (Claimed)	350+ GB (uncompressed)
Data Types (Claimed)	Mail server dumps, databases, confidential documents, contracts, and employee data
Service Impact	No disruption to the Europa.eu website availability
Internal Systems	NOT affected — architectural segmentation held
Notification Status	Potentially affected Union entities are being notified

2.2 Scope of Compromise: Confirmed vs Claimed

Based on multi-source reporting from BleepingComputer, TechCrunch, Bloomberg, Cybernews, Reuters, and the official EC press release (IP/26/748), the scope divides into three evidentiary tiers:

✓ CONFIRMED BY THE EUROPEAN COMMISSION

The cyberattack affected cloud infrastructure hosting the Europa.eu web platform. Early forensic findings indicate that data was taken from those websites. Internal systems were not affected. The incident was contained swiftly, and risk mitigation measures were deployed. Europa.eu websites experienced no operational downtime. The Commission is notifying Union entities that may have been affected.

⚠ CLAIMED BY THREAT ACTOR (SHINYHUNTERS) — UNVERIFIED

Exfiltration of 350+ GB of data, including multiple databases, mail server content, confidential documents, and contracts. Persistent access to an email server used by Commission employees—screenshots provided to BleepingComputer as proof of access to employee information. The actor stated they will not seek ransom and intend to leak the data publicly. Leak site posting dated 26 March 2026, updated 28 March 2026.

✓ CONFIRMED BY AWS (THIRD PARTY)

AWS infrastructure itself was not breached. AWS stated its services operated as designed. This confirms the compromise was a customer-side account breach, not a platform-level security failure — consistent with the AWS Shared Responsibility Model, where the customer owns security "in" the cloud (IAM, configuration, access controls). In contrast, AWS owns security "of" the cloud (infrastructure, compute, storage).

REGULATORY NOTE — EDPS NOTIFICATION OBLIGATIONS

The European Commission is subject to Regulation (EU) 2018/1725 (the data protection regulation for EU institutions), not GDPR. Under this regulation, personal data breaches must be reported to the European Data Protection Supervisor (EDPS) within 72 hours, where feasible.

If the breach poses a high risk to individuals' rights and freedoms, affected individuals must be informed without unnecessary delay.

Given the Commission's confirmation that data was taken and the threat actor's claims of access to employee data and email servers, EDPS notification requirements are almost certainly triggered.

2.3 Blast Radius Assessment

The Good: The Commission's architecture employed effective network segmentation between its public-facing cloud accounts and internal administrative networks. This "blast wall" prevented lateral movement into highly sensitive on-premise systems and is a genuine security win.

The Bad: A 350 GB haul is massive. If validated, the dataset may include personnel directories, full email archives, active session databases, or policy documents. Nick Tausek (Swimlane) assessed: the blast radius goes way beyond a single cloud admin account. Access to multiple databases, employee data, plus an email server opens the door to identity risk, operational disruption, and second-stage spearphishing attacks against EU officials. The Commission employs approximately 32,000 civil servants across 27 member states — the downstream exposure is substantial.

The Ugly: Even without extortion, Tausek warns that a quiet data leak can be equally damaging for trust, diplomacy, and ongoing investigations. If the January MDM breach (which exposed staff names and mobile numbers) is combined with the March email server and database exfiltration, then threat actors now possess a rich social-engineering toolkit targeting EU officials across multiple communication channels.

3. WHO — Threat Actor Attribution

3.1 Victim Profile

The primary victim is the European Commission, the executive arm of the European Union, specifically the public-facing Europa.eu platform and associated cloud infrastructure. The Commission employs approximately 32,000 civil servants and serves all 27 EU member states. Additional Union entities connected to or hosted on the Europa platform are also being notified of potential data exposure.

3.2 Claimed Actor: ShinyHunters

On 28 March 2026, cybersecurity researcher Dominic Alvieri reported on X (Twitter) that ShinyHunters had posted the European Commission to their Tor-based data leak site. Security Affairs, Hackread, and RedPacket Security subsequently confirmed the listing, which was dated 26 March 2026 and updated on 28 March 2026.

Attribute	Detail
Group Name	ShinyHunters
Active Since	2019 (first known operations)
Motivation	Financial extortion/data leaking ("pay or leak" model)
Known Alliances	Cybercrime collective with Scattered Spider and Lapsus\$ (formed 2025; 16+ Telegram channels)
Primary TTPs	Social engineering (vishing), credential harvesting, SaaS/cloud misconfiguration exploitation
Tooling (2026)	Modified Mandiant AuralInspector for Salesforce Aura mass-scanning
Notable Victims	Snowflake/Ticketmaster, AT&T, Santander, SoundCloud, Okta, LastPass, AMD, Sony, Salesforce, Mixpanel
Estimated Victims	300–400 organisations as of March 2026
Leak Post Date	26 March 2026 (updated 28 March 2026)

3.3 Threat Actor Profile & Operational Evolution

ShinyHunters is a prolific black-hat cybercrime and extortion group named after the “shiny hunting” mechanic in the Pokémon franchise. The group has evolved from selling stolen databases on dark web forums to a sophisticated operation that systematically targets enterprise cloud infrastructure at an industrial scale.

Their most significant 2025–2026 campaign weaponised Mandiant’s legitimate AuralInspector audit tool — released in January 2026 to help defenders identify Salesforce Experience Cloud misconfigurations — and turned it into a mass-scanning data-extraction weapon. By March 2026, ShinyHunters claimed to have collected data from 300–400 organisations via this vector alone. In November 2025, the group compromised the analytics provider Mixpanel via SMS phishing, gaining downstream access to data from OpenAI, SoundCloud (~28 million accounts), and other customers.

ShinyHunters' operational model is consistent: gain access through cloud credential theft, social engineering, or SaaS misconfiguration; exfiltrate data at scale; issue extortion demands. If payment is refused, data is leaked publicly. Dutch telecom Odido, which refused a reported one million euro ransom, saw millions of customer records dumped as a warning.

3.4 Mandiant/GTIG Threat Cluster Tracking

On 31 January 2026, Google Threat Intelligence Group (GTIG) / Mandiant published a comprehensive report tracking the expansion of ShinyHunters-branded SaaS data theft operations. Mandiant tracks this activity across three distinct threat clusters — UNC6661, UNC6671, and UNC6240 (ShinyHunters) — to account for evolving partnerships and potential impersonation activity. This is the most authoritative primary threat intelligence on ShinyHunters' current operational tradecraft.

Cluster	Tradecraft	Operational Detail
UNC6661	Vishing + SSO credential harvesting	Impersonates IT staff and directs victims to company-branded phishing sites (e.g., <company>sso.com or <company>internal.com). Captures SSO credentials and MFA codes, then registers attacker-controlled MFA device. Domains registered via NICENIC. Gained access to Okta customer accounts.
UNC6671	Vishing + credential harvesting (variant)	Similar approach to UNC6661, but uses Tucows for domain registration—leveraged PowerShell to download data from SharePoint and OneDrive. Extortion emails do not overlap with known UNC6240 indicators, suggesting distinct operators.
UNC6240	Post-intrusion extortion (ShinyHunters brand)	Conducts extortion using Tox messaging for negotiations, ShinyHunters-branded emails, and Limewire for hosting stolen data samples. Specifies a BTC payment address and threatens a DDoS attack if the ransom is not paid within 72 hours. Operates the ShinyHunters Tor data leak site.

Mandiant assesses this activity as opportunistic, with threat actors targeting any available SaaS applications via the compromised SSO session. However, the breadth of targeted cloud platforms continues to expand: beyond Salesforce (their historic primary target), recent campaigns have hit Microsoft 365, SharePoint, Slack, Atlassian, Dropbox, Google Drive, DocuSign, and other internal platforms. The SSO dashboard serves as a springboard to all cloud data accessible through a single compromised account.

Critically, Mandiant emphasises that this activity is not the result of a security vulnerability in any vendor's products or infrastructure. Instead, these intrusions rely on social engineering to bypass identity controls and pivot into cloud-based SaaS environments — a pattern directly consistent with the Europa.eu breach profile.

ATTRIBUTION CONFIDENCE: MEDIUM-HIGH

ShinyHunters claimed responsibility for the attack via their established Tor leak site. The claim is consistent with the group's known MO: cloud account targeting, large-scale exfiltration, and public leak threats.

However, the stated intention to leak rather than extort represents a deviation from ShinyHunters' typical "pay or leak" model, raising the question of whether this is genuinely ShinyHunters operating with a political sub-motive, or a different actor leveraging ShinyHunters' brand for attribution misdirection.

Independent technical verification linking specific IOCs or TTPs to ShinyHunters infrastructure has not been published as of the report date.

3.5 Expert Assessment on Motivation & Attribution

Ilia Kolochenko, CEO of ImmuniWeb, assessed the attackers as either hacktivists or cyber mercenaries hired by a nation-state, noting that the intent to leak rather than extort signals a goal of causing visible reputational and institutional damage. He predicted an avalanche of politically motivated attacks with destructive consequences through 2026, driven by global geopolitical turbulence, and warned that attackers in such cases rarely consider their costs and may persistently invest time and effort in sophisticated campaigns against the most protected organizations.

Nick Tausek of Swimlane noted that even without extortion, the impact remains severe, and highlighted that the Commission's legislative push for stricter cybersecurity regulation and digital sovereignty has likely elevated it as a target. He emphasized that policy moves can raise the temperature, invite probing, and accelerate adversary interest in supply chain weak spots, especially where cloud, third-party tooling, and identity controls intersect.

4. WHEN — Consolidated Incident Timeline

The following unified timeline places the Europa.eu breach within its full operational context, merging the primary incident sequence with the broader EU cyber threat landscape events that preceded and shaped it. Rows shaded in blue with italic text and a [CONTEXT] prefix represent contextual events; white rows represent incident-specific events.

Date	Event
20 Jan 2026	<i>[CONTEXT] European Commission unveils new Cybersecurity Package focused on strengthening EU network and supply chain security.</i>
29 Jan 2026	<i>[CONTEXT] Ivanti discloses CVE-2026-1281 and CVE-2026-1340, two critical EPMM code injection vulnerabilities (CVSS 9.8). CISA adds CVE-2026-1281 to KEV catalog same day. Exploitation is already active in the wild.</i>
30 Jan 2026	<i>[CONTEXT] CERT-EU detects traces of a cyberattack on the Commission's central MDM infrastructure. Staff names and mobile numbers may have been exposed and contained within 9 hours. No mobile devices compromised.</i>
30 Jan 2026	<i>[CONTEXT] Dutch Data Protection Authority (AP) and Council for the Judiciary (Rvdv) confirm compromise via Ivanti EPMM. Finland's Valtori reports breach affecting up to 50,000 government employees.</i>
06 Feb 2026	<i>[CONTEXT] Commission officially confirms January MDM breach via press release (IP/26/342).</i>
09–12 Feb 2026	<i>[CONTEXT] Researchers discover "sleeper" webshells deployed to /mifs/403.jsp on compromised EPMM instances by suspected initial access brokers. Pattern suggests foothold-then-sell tradecraft.</i>
16 Mar 2026	<i>[CONTEXT] EU COUNCIL ADOPTS NEW CYBER SANCTIONS targeting Chinese entities Integrity Technology Group (linked to Flax Typhoon / 65,000+ devices compromised) and Anxun/iSoon, plus Iranian entity Emennet Pasargad. Two Anxun co-founders were individually sanctioned. Total sanctions regime: 19 individuals, 7 entities.</i>
24 Mar 2026	European Commission detects cyberattack on its AWS cloud infrastructure hosting Europa.eu. Incident response is initiated immediately; containment and risk mitigation measures are deployed. Europa.eu websites remain operational.
~24–25 Mar	The Commission cybersecurity incident response team investigates the breach in coordination with CERT-EU. The compromised AWS environment is isolated. Credential rotation and access reviews initiated.
26 Mar 2026	ShinyHunters posts the European Commission's Tor data leak site, claiming 350+ GB of exfiltrated data, including mail server dumps, databases, confidential documents, and contracts. Post timestamped 2026-03-26 11:10:00 UTC.
~26 Mar 2026	Threat actor contacts BleepingComputer, providing screenshots as proof of access to employee data and a Commission email server. States no intention to extort; plans to leak data publicly at a later date.
27 Mar (AM)	BleepingComputer publishes its first report on the breach, citing sources confirming that at least one AWS account was compromised. AWS states its services were not breached.
27 Mar 2026	The European Commission publishes an official press release (IP/26/748) confirming the cyberattack and acknowledging that data may have been taken. EC spokesperson Nika Blazevic confirms the incident to TechCrunch.

27 Mar (PM)	Reuters, Bloomberg, Investing.com, CNA, and Anadolu Agency carry the story globally—expert analysis published by CSO Online, Cybernews, and CyberPress.
28 Mar 2026	Dominic Alvieri reports ShinyHunters' claim on X. Security Affairs, and Hackread confirm the Tor leak site listing. RedPacket Security logs the victim entry. The leak post is updated.
29 Mar 2026	Investigation ongoing. Full impact assessment not yet complete. Commission continues to monitor and notify potentially affected Union entities.

ANALYST NOTE — TEMPORAL CORRELATION

The 8-day gap between the EU Council's 16 March cyber sanctions against Chinese and Iranian offensive entities and the 24 March Europa platform breach is noteworthy on circumstantial grounds. While ShinyHunters (a financially motivated cybercrime group) has claimed responsibility, the deviation from their standard extortion model toward a free-leak strategy raises the question of whether a state-aligned actor commissioned or incentivised this operation.

This correlation does not establish causation but should be factored into attribution analysis as the investigation progresses.

5. WHERE — Attack Surface & Infrastructure

5.1 Target Environment

The attack specifically targeted the European Commission's Amazon Web Services (AWS) cloud infrastructure hosting its public-facing web presence on the Europa.eu platform. The Europa.eu domain is the principal public gateway for all EU institutional websites, legislation, press releases, public consultations, tenders, and policy materials. Any incident affecting this infrastructure has implications beyond a single department or service.

Dimension	Detail
Primary Target	Europa.eu web platform (EC's public-facing web presence)
Cloud Provider	Amazon Web Services (AWS)
Accounts Affected	At least one AWS account confirmed
Compromise Layer	Customer account management layer (IAM, credentials, API keys) — NOT AWS infrastructure
Geographic Context	Commission HQ: Brussels, Belgium; AWS region(s) undisclosed
Org Size	~32,000 civil servants across 27 member states
Internal Systems	NOT affected — network segmentation between public cloud and internal networks held
Service Continuity	Europa.eu websites remained available throughout the incident

5.2 Europa Platform Technology Stack & Attack Surface

The Europa.eu web estate is not a monolithic application but a large, heterogeneous platform spanning multiple frameworks and technology stacks. Commission web governance materials and public procurement documentation indicate the following components are present in the broader Europa web environment:

Component	Detail
Primary CMS	Drupal-based "Open Europa" corporate content management platform
Application Frameworks	Java, PHP, Perl/Apache, Node.js/Express, ColdFusion
Portal / Enterprise	Liferay portal framework
Authentication	EU Login (centralised SSO for EC staff and external users)
Hosting	AWS accounts owned by the Commission
Domain Estate	*.ec.europa.eu, *.commission.europa.eu, and related subdomains

This technology heterogeneity is analytically significant because it multiplies the number of plausible intrusion paths. A vulnerable Drupal admin interface, an exposed CI/CD pipeline

token, a misconfigured database connector, hardcoded secrets in a legacy ColdFusion application, or a compromised EU Login session could each independently provide an entry point to the cloud environment — without requiring an attack on AWS infrastructure itself. The mix of legacy and modern frameworks also increases the probability of unpatched components, inconsistent security configurations, and shadow dependencies across the web estate.

The Commission's Europa Web Guide describes this as the official rulebook for the Commission's web presence, governing standards across this diverse technology landscape. The breadth of this estate means that "public web presence" encompasses far more than static web pages — it includes backend databases, submission portals, staff-facing tools, API endpoints, and integration layers that may all have been within the blast radius of a cloud account compromise.

5.3 Architectural Segmentation & Shared Responsibility Assessment

A critical positive finding is that the Commission's network architecture prevented lateral movement from the compromised cloud environment into core internal systems. This segmentation between public-facing cloud infrastructure and internal administrative networks reflects cybersecurity best practices and likely prevented a far more severe compromise.

However, the breach starkly illustrates the tension in the AWS Shared Responsibility Model. AWS owns security "of" the cloud (the infrastructure, compute, storage, and networking layers) and confirmed no platform-level compromise. The Commission owns security "in" the cloud — meaning IAM configuration, access policies, credential management, and application-level security. The failure occurred entirely within this customer-owned domain. Misconfigured IAM roles, over-privileged accounts, exposed API keys, or hardcoded secrets in repositories are all prime suspects in this class of breach.

The volume of exfiltrated data (350+ GB) further suggests that the compromised credentials or applications had extensive read access privileges across the targeted AWS account, indicating a potential least-privilege violation in which services or administrators had broader permissions than operationally necessary.

INFRASTRUCTURE INSIGHT

The breach targeted the cloud account management layer (IAM, credentials, API keys) rather than the AWS platform itself — consistent with the AWS Shared Responsibility Model.

The 350 GB exfiltration volume should have triggered anomaly alerts via AWS GuardDuty, CloudTrail, or cloud-native SIEM tooling. Whether such monitoring was in place and why it did not prevent the full exfiltration are key questions in the investigation.

This pattern aligns with the broader 2026 trend: credential-based intrusions — where attackers leverage stolen or weak logins rather than exploit software vulnerabilities — remain the most widespread entry point in cloud environments.

6. WHY — Motive & Strategic Context

6.1 Stated Motive: Leak, Not Extort

The threat actor explicitly told BleepingComputer they will not attempt to extort the Commission and instead plan to publish the data online at a later date. This is a significant departure from ShinyHunters' established pay-or-leak model and pivots the incident away from cybercrime-for-financial-gain toward a disruptive, psychological, or politically aligned operation.

By leaking EU institutional data freely, the attackers achieve maximum embarrassment and reputational harm. This is particularly damaging as the Commission has been championing stricter cybersecurity legislation and digital sovereignty — a breach of its own systems directly undercuts that narrative.

6.2 Possible Motive Categories

Motive	Likelihood	Supporting Evidence
Reputational/political damage	HIGH	No ransom demand; intent to leak freely; timing relative to NIS2, Cyber Solidarity Act, and Cybersecurity Package advocacy; maximum embarrassment value for institution championing regulation.
Hacktivist alignment	MEDIUM-HIGH	Free-leak model inconsistent with financial extortion; Kolochenko's assessment of hacktivists or state-hired cyber mercenaries; geopolitical turbulence across Europe.
State-sponsored or state-incentivised	MEDIUM	8-day proximity to EU cyber sanctions against Chinese/Iranian entities; ShinyHunters' known alliance with Scattered Spider/Lapsus\$ (groups with suspected state-nexus contacts); deviation from financial extortion model.
Capability demonstration	MEDIUM	Breaching an EU institution provides ShinyHunters high-profile credentialing; useful for attracting buyers, collaborators, or future clients.
Purely financial (delayed)	LOW	While ShinyHunters may later attempt to sell the data, the explicit public statement that it will not engage in extortion reduces this likelihood.

6.3 Geopolitical Context: The 16 March Sanctions Factor

Eight days before the Europa breach, on 16 March 2026, the EU Council adopted new cyber sanctions targeting Integrity Technology Group and Anxun Information Technology from China, and Emennet Pasargad from Iran. These entities were involved in significant cyber incidents, including compromising over 65,000 IoT devices and spreading disinformation during the Paris 2024 Olympics. The sanctions expanded the EU's cyber sanctions regime to 19 individuals and 7 entities. The timing of these sanctions has been linked to the subsequent attack on 24 March, prompting discussions about digital sovereignty and the potential shift from American to European cloud vendors. However, such changes may not significantly enhance security without addressing identity and access management issues.

7. HOW — Attack Vector & Technical Analysis

7.1 Known and Assessed Attack Vectors

As of this report's publication, the precise attack vector has not been officially confirmed by the European Commission. The threat actor did not disclose to BleepingComputer how they breached the affected accounts. However, analysis of ShinyHunters' known TTPs, the nature of the compromise (the account management layer, not the infrastructure), and expert commentary provide a substantive basis for technical assessment.

ASSESSED ATTACK VECTORS (MEDIUM CONFIDENCE)

Based on ShinyHunters' known tradecraft and the customer-side nature of the compromise, the most probable initial access vectors — in order of assessed likelihood — are:

- (1) SOCIAL ENGINEERING: Voice phishing (vishing) or credential-harvesting campaigns targeting Commission IT staff or cloud administrators to obtain AWS IAM credentials, session tokens, or MFA bypass.
- (2) COMPROMISED IAM CREDENTIALS: Stolen or leaked Identity and Access Management keys, potentially from infostealer malware, credential stuffing, or exposed secrets in code repositories.
- (3) WEB APPLICATION VULNERABILITY: Exploitation of a vulnerability in an application hosted on the Europa platform to establish a foothold within the cloud environment and pivot to cloud management APIs.
- (4) MISCONFIGURATION: Over-privileged IAM roles, exposed API keys, hardcoded secrets in public repositories, or insufficiently restricted access policies on the Commission's AWS account.

7.2 ShinyHunters Known TTPs (MITRE ATT&CK Mapping)

ShinyHunters' operational playbook, as documented across their 2025–2026 campaigns, maps to the following MITRE ATT&CK techniques:

Tactic	Technique ID	Description
Initial Access	T1566.004 Vishing	Voice phishing to harvest credentials from cloud admins and IT staff. Primary initial access vector in SSO/Okta campaigns.
Initial Access	T1078 Valid Accounts	Using stolen credentials to authenticate to cloud services without triggering anomaly detection.
Initial Access	T1190 Exploit Public App	Exploiting misconfigurations in public-facing SaaS applications (e.g., Salesforce Experience Cloud guest user permissions).
Credential Access	T1528 Steal App Token	Harvesting API keys, session tokens, OAuth tokens, and cloud access credentials from compromised environments.
Discovery	T1580 Cloud Infra Discovery	Mapping cloud resources, storage buckets, databases, email servers, and IAM configurations post-access.
Collection	T1530 Cloud Storage Data	Exfiltrating data from cloud-hosted databases, S3 buckets, and object storage services.
Exfiltration	T1567 Exfil Over Web Svc	Transferring stolen data out via cloud APIs or web-based channels to attacker-controlled infrastructure.
Impact	Custom — Data Leak	Threatening or executing public data leaks for reputational damage, political impact, or extortion leverage.

7.3 Expert Technical Commentary

Kellman Meghu, CTO of DeepCove Cybersecurity, assessed the situation as bad and emphasised the need for AWS Identity Centre sign-on with no IAM-generated static keys and break-glass administrative procedures requiring dual-person authorisation with hardware tokens for root/admin accounts. He highlighted that identity access management is hard across all platforms and that a single mistake is sufficient for an attacker to gain access.

Meghu specifically recommended that the AWS root/admin account controlling all cloud infrastructure be stored outside AWS on a system that requires authorisation from both the CEO and CTO, using separate credentials and hardware tokens. This defence-in-depth approach ensures that even if one administrator's credentials are compromised via phishing, the attacker cannot unilaterally escalate to account-level administrative access.

The Tech Portal reported initial assessments indicating that the breach originated in the identity and access management layer of the Commission's cloud infrastructure. The volume of exfiltrated data (350+ GB) strongly suggests that the compromised credentials or application had extensive read access privileges across the targeted AWS account — a potential least-privilege violation.

7.4 Incident Response Actions (Confirmed & Assessed)

Based on official statements and expert reporting, the Commission's incident response included: immediate isolation of the compromised AWS environment upon detection on 24 March; deployment of rapid risk mitigation measures to protect services and data; credential rotation and access reviews across cloud accounts; enhanced monitoring of cloud activity for anomalous behavior and persistent access mechanisms; forensic investigation to determine full scope, method of compromise, and extent of data exfiltration; notification process initiated for potentially affected Union entities; and continuous network monitoring for secondary attack tools or backdoors. The Commission emphasised that it will continue to monitor the situation and take all necessary measures to ensure security.

7.5 Open Investigative Questions

From a technical incident-response perspective, the next decisive answers are likely to come from cloud identity telemetry and object-access logs, not from generic website uptime monitoring. AWS guidance for compromised-credential investigations specifies that responders should identify the exact IAM entity, the API calls used, timestamps, and source IP addresses. For S3 specifically, GuardDuty can surface suspicious GetObject, ListObjects, PutObject, and DeleteObject activity using CloudTrail data events. The following priority questions remain unanswered as of the report date:

Pri ori ty	Question	Why It Matters
P1	Which IAM principal, federated user, or role was abused? Was this long-lived key misuse (AKIA prefix), temporary STS credential abuse (ASIA prefix), or console-session compromise?	Determines whether the attack exploited static secrets (indicating poor credential hygiene) or dynamic session tokens (indicating SSO/federation compromise consistent with ShinyHunters' UNC6661/UNC6671 tradecraft).
P2	Did the actor perform reconnaissance within the AWS account before accessing the bulk data? (e.g., ListBuckets, DescribeInstances, GetCallerIdentity calls)	Reveals whether this was a targeted operation with pre-planned objectives or an opportunistic smash-and-grab after credential acquisition.
P3	Was there any defence evasion — such as altered logging, disabled CloudTrail trails, stopped GuardDuty detectors, or deleted telemetry?	AWS documentation flags anomalous delete/disable/stop APIs as important attacker signals. Defence evasion would indicate a more sophisticated actor with knowledge of AWS security controls.
P4	Were any EU Login, CMS admin, CI/CD pipeline, or contractor accounts abused in the web estate?	The Europa platform uses EU Login for authentication and multiple application frameworks. A compromised admin or build-pipeline credential could grant cloud access without direct theft of an IAM key.
P5	Did the actor reach only website content and related data stores, or also mail, staff metadata, or shared-service backends attached to the cloud tenancy?	Determines the true blast radius. The threat actor claims access to the email server; the Commission's statement is silent on this. The answer defines whether this is a web data breach or a broader institutional compromise.
P6	Is there any technical link between this March incident and the January MDM breach?	Two breaches in 60 days could be a coincidence, coordinated campaigns by different actors, or a single actor using the January breach (which exposed staff names and mobile numbers) as reconnaissance for March vishing/social engineering.

8. Strategic Implications & Outlook

8.1 Pattern Recognition: Escalating Institutional Targeting

This incident represents the second confirmed cyberattack against the European Commission in under two months. The January 2026 MDM breach (Ivanti EPMM zero-days / supply chain vulnerability exploitation) and the March 2026 AWS account compromise (cloud identity exploitation) demonstrate two fundamentally different attack vectors converging on the same institution. Combined with contemporaneous attacks on the Dutch Data Protection Authority, Dutch Council for the Judiciary, and Finland's Valtori, this establishes a clear pattern of sustained, multi-vector targeting against European governmental and regulatory institutions through early 2026.

8.2 Cloud Security Paradigm Shift

The incident reinforces the critical 2026 trend: cloud attacks increasingly exploit the identity and access management layer rather than platform-level vulnerabilities. AWS itself was not compromised; the failure was at the customer account management level. This distinction has profound implications for the Shared Responsibility Model. It highlights that infrastructure hardening alone is insufficient without rigorous identity governance, least-privilege enforcement, credential hygiene, and robust anomaly detection on data egress. The 350 GB exfiltration should have been detectable through cloud-native tooling such as AWS GuardDuty, CloudTrail, or integrated SIEM platforms — raising questions about whether such monitoring was active and appropriately calibrated.

8.3 The “No Ransom” Pivot: A New Playbook

The refusal to extort represents a strategically significant shift. By leaking data without financial demands, the attackers achieve targeted psychological and political impact: undermining public trust in the Commission's ability to protect its own assets while simultaneously creating second-order risks by weaponising exposed personnel data for spearphishing, vishing, and social engineering against EU officials. This playbook is particularly damaging for an institution that has positioned itself as Europe's cybersecurity regulatory champion.

8.4 Regulatory Ironies & Digital Sovereignty

Kolochenko highlighted the ironic dimension: the institution championing NIS2, the Cyber Solidarity Act, and the Cybersecurity Regulation has itself been breached twice in rapid succession. He characterised this as a grim warning that regulation is not a panacea against data breaches. The breach may fuel debates about digital sovereignty and European cloud alternatives. However, experts assess that this would be unlikely to produce material security improvements without addressing underlying identity and access management challenges.

8.5 Forward-Looking Threat Assessment

FORWARD THREAT ASSESSMENT

HIGH PROBABILITY: ShinyHunters will leak the exfiltrated data within weeks to months, consistent with their established pattern and public statements.

HIGH PROBABILITY: Stolen employee data from both the January MDM breach and March cloud breach will be combined and weaponised for targeted phishing, vishing, and social engineering against EU officials across multiple channels.

MEDIUM-HIGH PROBABILITY: Additional EU institutions and agencies will face similar cloud account and SaaS targeting through 2026, driven by the escalating political motivation and the ShinyHunters/Scattered Spider/Lapsus\$ collective's expanding operations.

MEDIUM PROBABILITY: Other threat actors will attempt to exploit any remaining access or leverage leaked data for secondary attacks against Union entities.

MEDIUM PROBABILITY: The 16 March sanctions against Chinese and Iranian cyber-offensive entities will provoke further retaliatory operations against EU institutional targets, whether through ShinyHunters or other proxies.

ONGOING: The convergence of ShinyHunters, Scattered Spider, and Lapsus\$ (2025 collective formation) amplifies the scale and sophistication of future campaigns targeting high-profile government targets.

9. Defensive Recommendations

Based on the assessed attack profile, ShinyHunters' known TTPs, the AWS Shared Responsibility Model failure, and expert commentary, the following defensive measures are recommended for organisations operating in analogous cloud environments:

9.1 Identity & Access Management (Priority 1)

- Enforce hardware-backed MFA (FIDO2/WebAuthn) on all cloud administrative accounts, API interactions, and console logins. Eliminate IAM-generated static access keys in favour of AWS Identity Centre SSO with short-lived, auto-rotating credentials.
- Implement break-glass procedures for root/admin accounts that require dual-person authorisation with hardware tokens, stored outside the cloud environment on a system that requires CEO+CTO (or equivalent) co-authentication.
- Audit and enforce least-privilege IAM policies. Ensure applications and service accounts have only the exact permissions required. The 350 GB exfiltration volume suggests over-scoped read access that should have been constrained.
- Scan all code repositories (including historical commits) for hardcoded secrets, API keys, and embedded credentials. Deploy automated secret-scanning tools (e.g., git-secrets, TruffleHog) in CI/CD pipelines.

9.2 Detection & Monitoring (Priority 2)

- Deploy continuous cloud security posture management (CSPM) with real-time alerting on IAM policy changes, unusual data access patterns, anomalous API activity, and bulk data egress. Ensure AWS GuardDuty (or equivalent) is active, and thresholds are calibrated — a 350 GB exfiltration should trigger severe anomaly alerts.
- Enable comprehensive CloudTrail logging across all accounts and regions. Feed logs into a cloud-native SIEM with automated detection rules for credential abuse, privilege escalation, and data exfiltration patterns.

9.3 Architecture & Blast Radius Reduction (Priority 3)

- Segment cloud-hosted employee-facing services (email servers, directory services) from public web content hosting. Treat public-facing cloud environments as inherently untrusted zones with strict logical separation from internal Active Directory, core databases, and administrative systems.
- Implement AWS Organisations with Service Control Policies (SCPs) to enforce guardrails across all accounts. Use separate AWS accounts for different risk tiers (public web, internal services, administrative).

9.4 Human Layer Resilience (Priority 4)

- Conduct targeted social engineering resilience training for cloud administrators and IT staff, with specific emphasis on vishing (voice phishing) scenarios — ShinyHunters' documented primary initial access vector for credential harvesting.
- Review and minimise guest user permissions on SaaS platforms, particularly for Salesforce Experience Cloud instances, given ShinyHunters' concurrent AuralInspector campaign affecting 300–400 organisations.

9.5 Immediate Downstream Actions

- Prepare for downstream impact: rotate all credentials that may have been exposed in the January and March breaches, monitor for phishing campaigns using leaked employee data (names, mobile numbers, email addresses), and brief leadership on the likelihood that data will be published within weeks.
- Conduct tabletop exercises specifically simulating a combined vishing + leaked-data social engineering attack against senior officials, using the combined January (MDM) and March (cloud) data exposure as the threat scenario.

10. Sources & References

The following sources were consulted in the preparation of this report. All URLs were accessed on or before 29 March 2026.

10.1 Official Statements & Primary Reporting

#	Source	Title / Description	URL
1	European Commission	Press Release IP/26/748 — Commission responds to cyber-attack on its Europa web platform (27 Mar 2026)	ec.europa.eu/commission/presscorner/detail/en/ip_2...
2	BleepingComputer	European Commission investigating breach after Amazon cloud account hack (27 Mar 2026)	www.bleepingcomputer.com/news/security/european-co...
3	TechCrunch	European Commission confirms cyberattack after hackers claim data breach — Zack Whittaker (27 Mar 2026)	techcrunch.com/2026/03/27/european-commission-conf...
4	Bloomberg	European Commission's Data Stolen in Hack on AWS Account (27 Mar 2026)	www.bloomberg.com/news/articles/2026-03-27/europea...
5	Reuters	EU Commission web platform hit by cyber-attack on March 24 (27 Mar 2026)	www.yahoo.com/news/articles/eu-commission-platform...
6	Channel News Asia	EU Commission web platform hit by cyber-attack on March 24 (27 Mar 2026)	www.channelnewsasia.com/business/eu-commission-web...
7	Anadolu Agency	EU Commission investigates cyberattack on its public website platform (27 Mar 2026)	www.aa.com.tr/en/europe/eu-commission-investigates...

10.2 Threat Actor Attribution & Dark Web Reporting

#	Source	Title / Description	URL
1	Security Affairs	ShinyHunters claims the hack of the European Commission — Pierluigi Paganini (28 Mar 2026)	securityaffairs.com/190095/data-breach/shinyhunter...
2	Hackread	ShinyHunters Claims 350GB Data Breach at European Commission — Waqas (28 Mar 2026)	hackread.com/shinyhunters-350gb-data-breach-europe...
3	RedPacket Security	Ransomware Victim Listing: European Commission (ShinyHunters) (28 Mar 2026)	www.redpacketsecurity.com/shinyhunters-ransomware-...
4	Google Cloud / GTIG	Tracking the Expansion of ShinyHunters-Branded SaaS Data Theft — Mandiant (31 Jan 2026)	cloud.google.com/blog/topics/threat-intelligence/e...
5	Google Cloud / GTIG	Proactive Defence Against ShinyHunters-Branded Data Theft Targeting SaaS (31 Jan 2026)	cloud.google.com/blog/topics/threat-intelligence/d...
6	BleepingComputer	Mandiant details how ShinyHunters abuse SSO to steal cloud data (31 Jan 2026)	www.bleepingcomputer.com/news/security/mandiant-de...
7	Wikipedia	ShinyHunters (accessed 29 Mar 2026)	en.wikipedia.org/wiki/ShinyHunters
8	Mayhemcode	ShinyHunters Hacking Group Explained: 400 Companies Breached (Mar 2026)	www.mayhemcode.com/2026/03/shinyhunters-hacking-gr...
9	State of Surveillance	ShinyHunters Weaponised a Security Tool to Breach 400 Companies via Salesforce (Mar 2026)	stateofsurveillance.org/news/shinyhunters-salesfor...

10.3 Expert Analysis & Security Commentary

#	Source	Title / Description	URL
1	Cybernews	Hackers steal data from European Commission in AWS cloud breach (28 Mar 2026)	cybernews.com/news/european-commission-aws-cloud-b...
2	CSO Online	European Commission data stolen in a cyberattack on the infrastructure hosting its websites (28 Mar 2026)	www.csoonline.com/article/4151363/european-commiss...
3	Cyber Security News	European Commission Confirms Cyberattack After AWS Account Hack (28 Mar 2026)	cybersecuritynews.com/european-commission-aws-hack
4	GBHackers / CyberPress	European Commission Confirms Cyberattack After AWS Account Breach (28 Mar 2026)	cyberpress.org/aws-account-breach/
5	The Tech Portal	European Commission hit by data breach in AWS cloud system (28 Mar 2026)	thetechportal.com/2026/03/28/european-commission-h...
6	IBTimes Singapore	Cyberattacks Wreak Havoc as EU Commission Cloud Platform Breached (28 Mar 2026)	www.ibtimes.sg/cyberattacks-wreak-havoc-eu-commiss...
7	EU Today	European Commission says cyberattack hit Europa web platform (27 Mar 2026)	eutoday.net/european-commission-says-cyberattack-h...
8	MLQ.ai	EU Executive Probes Extent of Cyber Breach (28 Mar 2026)	mlq.ai/news/eu-executive-probes-extent-of-cyber-br...

10.4 Prior Incidents & Contextual Intelligence

#	Source	Title / Description	URL
1	Help Net Security	European Commission hit by cyberattackers targeting mobile management platform (09 Feb 2026)	www.helpnetsecurity.com/2026/02/09/european-commis...
2	BleepingComputer	European Commission discloses breach that exposed staff data (07 Feb 2026)	www.bleepingcomputer.com/news/security/european-co...
3	GreyNoise	Active Ivanti Exploitation Traced to Single Bulletproof IP (Feb 2026)	www.greynoise.io/blog/active-ivanti-exploitation
4	The Hacker News	Dutch Authorities Confirm Ivanti Zero-Day Exploit (12 Feb 2026)	thehackernews.com/2026/02/dutch-authorities-confir...
5	Help Net Security	Ivanti EPMM exploitation: Researchers warn of sleeper webshells (12 Feb 2026)	www.helpnetsecurity.com/2026/02/11/ivanti-epmm-sle...
6	EU Council	Cyber-attacks against the EU: Council sanctions three entities and two individuals (16 Mar 2026)	www.consilium.europa.eu/en/press/press-r...
7	BankInfoSecurity	EU Belatedly Sanctions Chinese and Iranian Hackers (17 Mar 2026)	www.bankinfosecurity.com/eu-belatedly-sa...
8	Dark Reading	EU Sanctions Companies in China & Iran for Cyberattacks (Mar 2026)	www.darkreading.com/threat-intelligence/eu-sanctio...
9	European Commission	Commission responds to cyber-attack on its central mobile infrastructure (IP/26/342) (06 Feb 2026)	ec.europa.eu/commission/presscorner/det...
10	EU	CERT-EU — Cybersecurity Service for Union Institutions, Bodies, Offices and Agencies	European-Union.europa.eu/institutions-law-budg...

10.5 Technical References & Platform Documentation

#	Source	Title / Description	URL
1	European Commission	Europa Web Guide — Official rulebook for the Commission's web presence	commission.europa.eu/resources/europa-web-guide_e...

2	European Commission	Europa IT Platform — Drupal Core 9.3.x end-of-life and VCS clean-up (Newsletter Archives)	ec.europa.eu/newsroom/informatics/newsletter-archi...
3	AWS Documentation	Remediating potentially compromised AWS credentials — GuardDuty guidance	docs.aws.amazon.com/guardduty/latest/ug/compromise...
4	AWS Documentation	GuardDuty S3 Protection — S3 data-event monitoring and anomaly detection	docs.aws.amazon.com/guardduty/latest/ug/s3-protect...
5	AWS Documentation	GuardDuty IAM finding types — Defence evasion and credential abuse indicators	docs.aws.amazon.com/guardduty/latest/ug/guardduty ...
6	Google Cloud / GTIG	M-Trends 2026 — Data, Insights, and Strategies From the Frontlines (24 Mar 2026)	cloud.google.com/blog/topics/threat-intelligence/m...

— END OF REPORT —